



■ MERIDIAN CYBER · 2026 EDITION

The DFSA & FSRA Cyber Readiness Checklist

*A 38-point self-assessment
for DIFC and ADGM authorised firms*

Published by **Meridian Cyber Ltd**

London · Dubai

meridiancyber.ai

■ INTRODUCTION

Two cyber rule sets now bind every UAE financial-zone firm.

DFSA Cyber Risk Management Rules (GEN 5.5) took effect 1 January 2024 and apply to every DIFC-authorized firm, registered auditor, credit rating agency and authorised market institution.

FSRA Cyber Risk Management Rules (GEN 3.5) took effect 31 January 2026 and apply to every ADGM Authorised Person and Recognised Body, with the limited exception of representative offices.

Both regulators expect a documented framework, named senior accountability, board-level oversight, incident response readiness, third-party cyber risk management, and rapid notification of material incidents — within 24 hours under FSRA GEN 3.5.18, and "without undue delay" under DFSA GEN 5.5.17.

How to score

This checklist is a 38-point self-assessment. Score each item honestly:

- **Green** = documented, evidenced, board-approved, tested in the last 12 months
- **Amber** = partially in place, gaps known, work in progress
- **Red** = absent, undocumented, or has not survived contact with reality

If you score green on fewer than 30 of the 38 items, you are not in a defensible position for a thematic review or a live incident. Most firms self-assess at 20–25 green on first pass.

■ SECTION 1 — GOVERNANCE AND ACCOUNTABILITY

Section 1 — Governance and accountability

1. A documented Cyber Risk Management Framework exists, approved by the governing body, with a recorded approval date in the last 12 months ■ G ■ A ■ R
2. A named senior individual is accountable for the framework, with written terms of reference and direct access to the board ■ G ■ A ■ R
3. Cyber risk is a standing agenda item at the relevant board or risk committee, with documented minutes for at least the last four meetings ■ G ■ A ■ R
4. Cyber risk appetite is articulated in writing, signed off by the board, and reviewed annually ■ G ■ A ■ R
5. Roles and responsibilities for cyber are mapped across senior management, with no gaps and no overlaps that create ambiguity ■ G ■ A ■ R

■ SECTION 2 — RISK IDENTIFICATION AND ASSESSMENT

Section 2 — Risk identification and assessment

6. A current ICT asset inventory exists, classified by confidentiality and business criticality, including third-party-hosted assets ■ G ■ A ■ R
7. A cyber risk register exists, with each risk owned, scored, and reviewed within the last six months ■ G ■ A ■ R
8. Threat modelling has been performed against the firm's critical operations, not generic threats ■ G ■ A ■ R
9. Risk assessment methodology is documented and consistently applied ■ G ■ A ■ R

■ SECTION 3 — CONTROLS

Section 3 — Controls

- 10. Access control policies enforce least-privilege, with privileged access reviewed quarterly ■ G ■ A ■ R
- 11. Multi-factor authentication is enforced on all administrative access and all remote access ■ G ■ A ■ R
- 12. Data classification policy is documented, applied, and audited ■ G ■ A ■ R
- 13. Encryption is applied to data at rest and in transit, with a documented key management approach ■ G ■ A ■ R
- 14. Endpoint protection is deployed, monitored, and producing logs reviewed at least weekly ■ G ■ A ■ R
- 15. Patch management has documented timelines by severity, and current patching evidence is retained ■ G ■ A ■ R
- 16. Backup arrangements are tested, with the last successful restore documented within the last 12 months ■ G ■ A ■ R

■ SECTION 4 — MONITORING AND DETECTION

Section 4 — Monitoring and detection

- 17. Security event monitoring is in place, with either an internal team or a documented MSSP arrangement ■ G ■ A ■ R
- 18. Logs are retained for the period required by your sector, with retention evidenced ■ G ■ A ■ R
- 19. Detection rules are reviewed at least annually for relevance to current threats ■ G ■ A ■ R
- 20. Vulnerability scanning is performed at least quarterly, with results triaged and remediated ■ G ■ A ■ R
- 21. Independent penetration testing has been performed within the last 12 months, with findings tracked to closure ■ G ■ A ■ R

■ SECTION 5 — INCIDENT RESPONSE

Section 5 — Incident response

- 22. A documented Cyber Incident Response Plan exists, with named roles, escalation paths, and contact details ■ G ■ A ■ R
- 23. The plan includes the regulatory notification pathway: who notifies the DFSA or FSRA, in what timeframe, in what format ■ G ■ A ■ R
- 24. The plan has been exercised in the last 12 months via tabletop or live drill, with documented outcomes ■ G ■ A ■ R
- 25. Material incident criteria are defined in writing, so the firm knows what triggers notification ■ G ■ A ■ R
- 26. Lessons learned from any actual incidents in the last 24 months have been captured and fed back into the framework ■ G ■ A ■ R

■ SECTION 6 — THIRD-PARTY CYBER RISK

Section 6 — Third-party cyber risk

- 27. A current register of third-party providers and their cyber risk rating exists ■ G ■ A ■ R
- 28. Cyber risk is assessed at onboarding for every new third party, with documented criteria ■ G ■ A ■ R
- 29. Material third parties are reassessed at least annually ■ G ■ A ■ R
- 30. Contracts with material third parties include cyber clauses: security obligations, audit rights, incident notification, sub-processor approval ■ G ■ A ■ R
- 31. The MSP or outsourced IT provider, specifically, has been assessed within the last 12 months under the firm's third-party cyber framework ■ G ■ A ■ R

■ SECTION 7 — TRAINING AND AWARENESS

Section 7 — Training and awareness

- 32. All staff have completed cyber awareness training in the last 12 months, with evidence retained ■ G ■ A ■ R
- 33. Board members have received cyber-specific governance training, not generic awareness ■ G ■ A ■ R
- 34. Phishing simulation has been run in the last 12 months, with results tracked ■ G ■ A ■ R

■ SECTION 8 — BUSINESS CONTINUITY

Section 8 — Business continuity

- 35. A documented Business Continuity Plan exists, with critical functions mapped and RTO/RPO defined per function ■ G ■ A ■ R
- 36. The BCP has been exercised in the last 12 months, with documented outcomes ■ G ■ A ■ R
- 37. Third-party and outsourcing arrangements are covered by the firm's BCP scope ■ G ■ A ■ R
- 38. The BCP is maintained: reviewed at least annually, updated for material changes ■ G ■ A ■ R

How to interpret your score.

38 green

Your framework is in defensible shape. Maintain the cadence. The risk now is drift — annual reviews, exercise refreshes, and rule-change monitoring.

30–37 green

You're broadly there with manageable gaps. Most firms in this band will close the gaps inside 90 days with focused effort.

20–29 green

Common starting point. A documented framework, policy pack, and first board review cycle inside six months is realistic.

Fewer than 20 green

Material exposure. If a thematic review or incident lands before this is fixed, the outcome will be difficult. Engage senior cyber leadership now — internally or fractionally.

Next steps

Meridian Cyber advises DFSA and FSRA authorised firms on the framework, programme, and governance work this checklist covers — alongside a broader cybersecurity practice serving regulated enterprises across financial services, hospitality, healthcare, and critical infrastructure.

A 30-minute discovery call costs you nothing and either confirms you're on track, or maps the gap honestly. Engagements are scoped to your licence category, firm size, and nearest regulatory pressure point — with transparent monthly retainers and 30-day notice.

Book a discovery call

meridiancyber.ai/#contact
ajay@meridiancyber.ai

This checklist is provided for informational purposes. It is not a substitute for legal, regulatory, or compliance advice. Meridian Cyber Ltd is a company registered in England and Wales.

© 2026 Meridian Cyber Ltd · meridiancyber.ai · London · Dubai